

Q/CUP

中国银联股份有限公司企业标准

Q/CUP 046.6.2—2014

代替Q/CUP 046.6.2-2012

中国银联 IC 卡技术规范——辅助规范 第 6 部分 金融 IC 卡借记/贷记应用根 CA 公钥认证规范——技术规范

China UnionPay integrated circuit card specifications

—auxiliary specifications

Part 6 Financial IC Card Debit/Credit Applications Root CA Public Key

Authentication Specification——Technical Specification

2014-11-30 发布

2014-11-30 实施

中国银联股份有限公司 发布

目 次

前 言	II
1 范围	1
2 规范性引用文件	1
3 术语和定义	1
4 编码符号表示	2
5 金融 IC 卡借记/贷记应用公钥认证	2
5.1 金融 IC 卡借记/贷记应用中的 IC 卡数据认证	3
5.2 金融 IC 卡借记/贷记应用使用的公钥种类	7
6 根 CA 公钥文件	7
6.1 根 CA 公钥文件命名	7
6.2 根 CA 公钥文件内容	7
6.3 未签名根 CA 公钥输出扩展	7
6.4 自签名根 CA 公钥	8
7 成员机构根 CA 公钥证书验证	9
8 发卡机构公钥输入文件	10
8.1 基本要求	10
8.2 发卡机构公钥输入文件命名	10
8.3 发卡机构公钥输入文件结构	10
8.4 发卡机构公钥输入文件格式	10
9 发卡机构公钥输入文件的验证	12
10 发卡机构公钥输出文件	13
10.1 发卡机构公钥证书输出文件命名	13
10.2 发卡机构公钥证书输出文件结构	13
10.3 未签名发卡机构公钥输出扩展	14
10.4 签名的发卡机构公钥证书	14
10.5 根 CA 单独签名	15
11 发卡机构公钥证书验证	15
参考文献	17

中国银联股份有限公司（以下简称“中国银联”）对该规范文档保留全部知识产权权利，包括但不限于版权、专利、商标、商业秘密等。任何人对该规范文档的任何使用都要受限于在中国银联成员机构服务平台（<http://member.unionpay.com/>）与中国银联签署的协议之规定。中国银联不对该规范文档的错误或疏漏以及由此导致的任何损失负任何责任。中国银联针对该规范文档放弃所有明示或暗示的保证,包括但不限于不侵犯第三方知识产权。

未经中国银联书面同意，您不得将该规范文档用于与中国银联合作事项之外的用途和目的。未经中国银联书面同意，不得下载、转发、公开或以其它任何形式向第三方提供该规范文档。如果您通过非法渠道获得该规范文档，请立即删除，并通过合法渠道向中国银联申请。

中国银联对该规范文档或与其相关的文档是否涉及第三方的知识产权（如加密算法可能在某些国家受专利保护）不做任何声明和担保，中国银联对于该规范文档的使用是否侵犯第三方权利不承担任何责任，包括但不限于对该规范文档的部分或全部使用。

前 言

本标准对金融IC卡借记/贷记应用根CA公钥认证及服务在技术及系统接口方面的要求做了规定。

本标准由中国银联股份有限公司提出。

本标准由中国银联股份有限公司制定。

本标准由中国银联股份有限公司技术部归口。

本标准起草单位：中国银联股份有限公司。

本次2014年对规范进行重新编号，规范内容不变。

本标准主要起草人：刘先、徐晋耀、徐志忠、杨辅祥、李春欢、柏建宁、隆永红、赵宇、黄发国、姜红。

中国银联
版权所有

中国银联 IC 卡技术规范——辅助规范

第 6 部分 金融 IC 卡借记/贷记应用根 CA 公钥认证规范 ——技术规范

1 范围

本标准规定了金融IC卡借记/贷记应用根CA公钥认证的技术要求和系统接口。

本标准适用于金融IC卡借记/贷记应用根CA公钥认证的服务提供机构和服务接受机构，包括认证管理机构、接受认证服务的中国银联成员机构以及中国银联成员机构授权的代理机构。

2 规范性引用文件

下列文件中的条款通过本标准的引用而成为本标准的条款。凡是注日期的引用文件，其随后所有的修改单（不包括勘误的内容）或修订版均不适用于本标准，然而，鼓励根据本标准达成协议的各方研究是否可使用这些文件的最新版本。凡是不注日期的引用文件，其最新版本适用于本标准。

JR/T 0025-2013 中国金融集成电路（IC）卡规范

JR/T 0003-2001 银行卡联网联合安全规范

中国银联，《银联卡业务运作规章》第七卷《IC卡业务规则》，2005年

中国银联，银联卡密钥安全管理规则，2004年8月

中国银联，金融IC卡借记/贷记应用根CA公钥认证管理规则

3 术语和定义

3.1

发卡机构标识代码 Bank Identification Number; BIN
用于标识发卡机构的代码。

3.2

EMV

EMV是EUROPAY、MasterCard、VISA三个国际信用卡公司的首字母缩略词，这三个公司联合制定的IC卡借记/贷记应用标准，简称为EMV标准。

3.3

入网机构标识码 institution identification code

在银行卡网络上唯一地标识受理方、发卡方、交换中心等机构的代码，通常用于ISO 8583报文中的下列数据元：

域32: Acquiring Institution Identification Code。

域33: Forwarding Institution Identification Code。

域99: Settlement Institution Identification Code。

3.4

成员机构 (Member organisation)

在本标准中指中国银联成员机构。

3.5

金融 IC 卡借记/贷记应用根 CA(Financial IC Card Debit/Credit Applications Root CA)

由中国人民银行授权建立的、由中国银联统一管理的服务于金融行业IC卡安全应用的根认证中心，以下简称“根CA”。实现该根认证中心功能的应用系统是“金融IC卡借记/贷记应用根CA系统”，以下简称“根CA系统”。

3.6

发卡机构(Issuer)

指开展金融IC卡发卡业务的成员机构。

3.7

收单机构 (Acquirer)

指开展金融IC卡收单业务的成员机构。

3.8

主账号 primary account number; PAN

标识发卡机构和持卡人信息的数字代码。它由发卡机构标识代码、个人账户标识和校验位组成，是银行卡金融交易的主要账号，在银行卡金融交易中等同于卡号。

3.9

RID, Registered application provider identifier

已注册的应用提供者标识。

3.10

公钥密码算法(Public key cryptographic algorithm)

《中国金融集成电路 (IC) 卡规范 》第七部分第十二章规定的公钥密码算法。

3.11

哈希算法(Hash algorithm)

《中国金融集成电路 (IC) 卡规范 》第七部分第十二章规定的哈希算法。

3.12

静态数据认证, Static data authentication; SDA

终端认证卡片中静态数据的签名，是脱机数据认证的一种。这种认证用于防止对卡片中关键个性化数据的篡改。

3.13

动态数据认证, Dynamic data authentication; DDA

芯片卡对特定交易数据元进行签名，终端验证该签名，是脱机数据认证的一种。这种认证用于防止卡片的非法复制、伪造。

3.14

CDA, Combined dynamic data authentication/application cryptogram generation

复合动态数据认证/应用密文生成，是脱机动态数据认证的一种。这种认证用于防止卡片的非法复制、伪造，同时生成交易密文。

4 编码符号表示

本标准定义的编码方式符合《中国金融集成电路 (IC) 卡规范 》，并与EMV2000标准兼容，同时兼容VISA、MasterCard、JCB等国际信用卡公司的有关规范及其支付系统。这些编码方式如下：

b： 二进制编码。用无符号二进制表示数据的一种方式。例如十进制数值的公钥指数3和65537，其二进制编码用十六进制表示则为 (hex) ‘03’ 和(hex) ‘01 00 01’ 。

cn： 压缩数字编码。每一字节表示两个十进制数字，具有固定长度，不足部分在右边以 ‘F’ 填充。如主帐号 (PAN)： 6123567890123 以长度为8的 ‘cn’ 编码值为： ‘61 23 56 78 90 12 3F FF’ 。

n： 数字编码。每一字节表示两个十进制数字，具有固定长度，不足部分在左边以十六进制字符 ‘0’ 填充。例如以长度为10的 ‘n ’ 编码表示十进制数值1234567为： ‘00 01 23 45 67’ 。

5 金融 IC 卡借记/贷记应用公钥认证

5.1 金融 IC 卡借记/贷记应用中的 IC 卡数据认证

金融IC卡借记/贷记应用公钥认证在IC卡支付过程中的作用是进行脱机IC卡数据认证，包括：

——静态数据认证（SDA）

——动态数据认证（DDA），包括：

- 标准动态数据认证
- 复合动态数据认证/应用密文生成（CDA）

这两种IC卡数据认证遵循《中国金融集成电路（IC）卡规范》，并与EMV2000规范兼容。

5.1.1 静态数据认证（SDA）

静态数据认证由终端验证卡片中的静态数据的数字签名来完成。其目的是确认存放在银联标准IC卡中关键的静态数据的合法性，可以发现在卡片个人化以后对卡内的发卡机构数据未经授权的改动，能有效地检测银联标准IC卡内关键静态数据的真实性。

静态数据认证流程和银联标准IC卡与根CA公钥认证体系之间的关系如图1所示：

整个银联标准IC卡静态数据认证的过程说明如下：

- 1) 发卡机构的密钥管理系统产生发卡机构公/私钥对 P_i 和 S_i ，并将公钥 P_i 传送至根 CA；
- 2) 根 CA 用自己的私钥 S_{CA} 对发卡机构公钥 P_i 进行数字签名，产生发卡机构公钥证书，连同根 CA 公钥证书（包括 RID 及根 CA 公钥索引）返回给发卡机构密钥管理系统；
- 3) 发卡机构密钥管理系统用发卡机构私钥 S_i 对卡片静态数据进行数字签名，将签名结果、发卡机构公钥证书、RID 及根 CA 公钥索引传送至发卡系统；
- 4) 发卡系统在个人化时将静态数字签名、发卡机构公钥证书、RID 以及根 CA 公钥索引写入每一张卡片中；
- 5) 根 CA 将其公钥 P_{CA} 、RID、根 CA 公钥索引及其它相关信息经收单机构传送至终端管理系统；
- 6) 收单机构终端管理系统把根 CA 公钥 P_{CA} 、RID、根 CA 公钥索引及其它相关信息下载至终端；
- 7) 银联标准 IC 卡进行交易时，脱机静态数据认证过程如下：
 - 终端从卡片中读取发卡机构公钥证书及签名数据，使用根 CA 公钥索引和 RID 找到根 CA 公钥 P_{CA} ，由 P_{CA} 恢复出发卡机构公钥 P_i 并验证其有效性；
 - 终端使用恢复的发卡机构公钥 P_i 验证卡片签名数据的有效性。

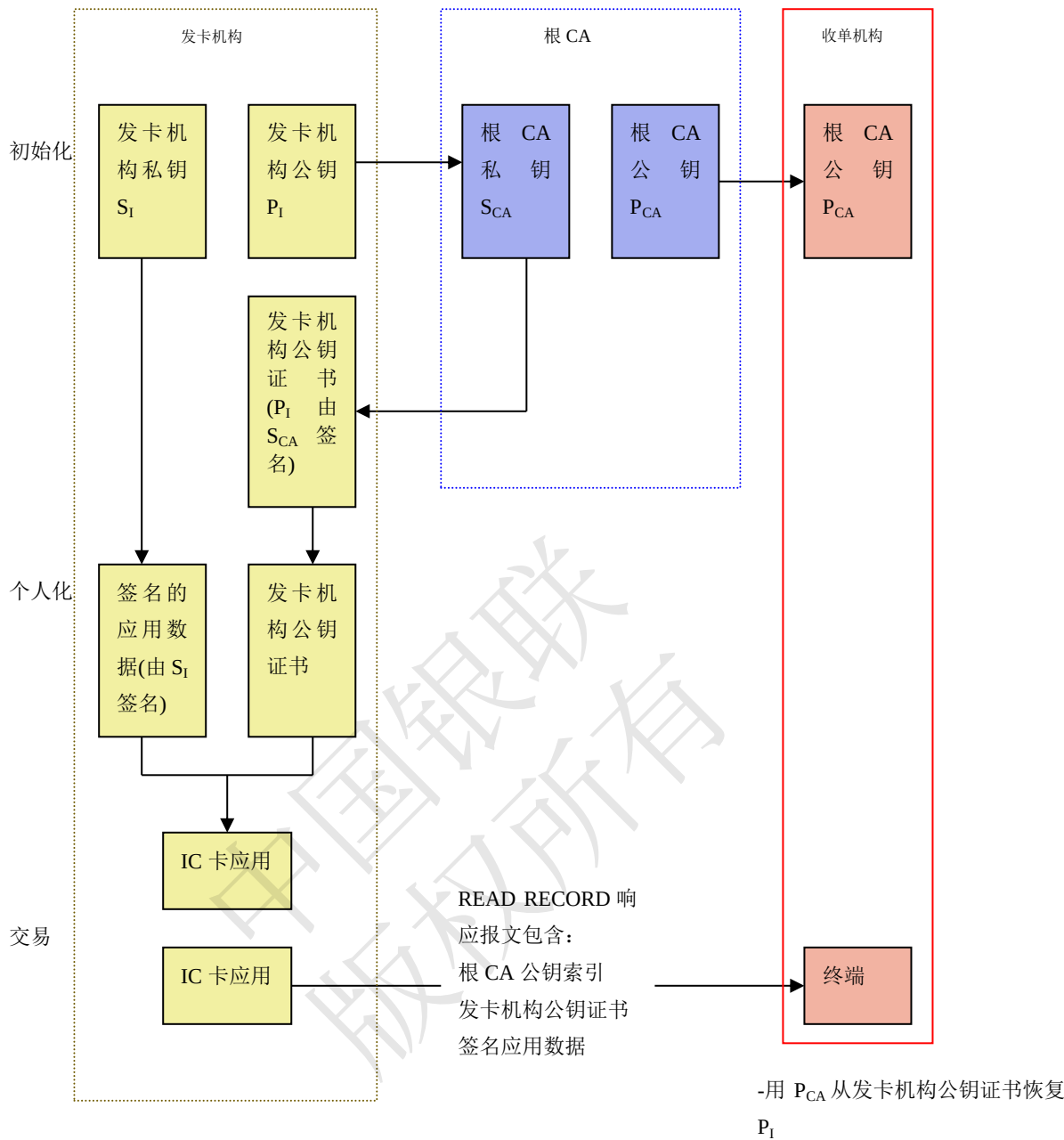


图1 银联 IC 卡静态数据认证

5.1.2 标准动态数据认证

在动态数据认证（DDA）过程中，终端验证卡片上的静态数据以及卡片产生的当前动态交易数据的签名。DDA能确认卡片上的发卡机构应用数据自卡片个人化后没有被非法篡改，更重要的是DDA还能确认卡片的真实性，防止卡片的非法复制和伪造。

DDA可以是标准动态数据认证或复合动态数据认证/应用密文生成（CDA）。银联标准IC卡动态数据认证如图2所示。

在这种方式下，银联标准IC卡将来自卡片的动态交易数据以及由动态数据认证数据对象列表（DDOL）所标识的终端数据生成一个数字签名（见《中国金融集成电路（IC）卡规范》）。

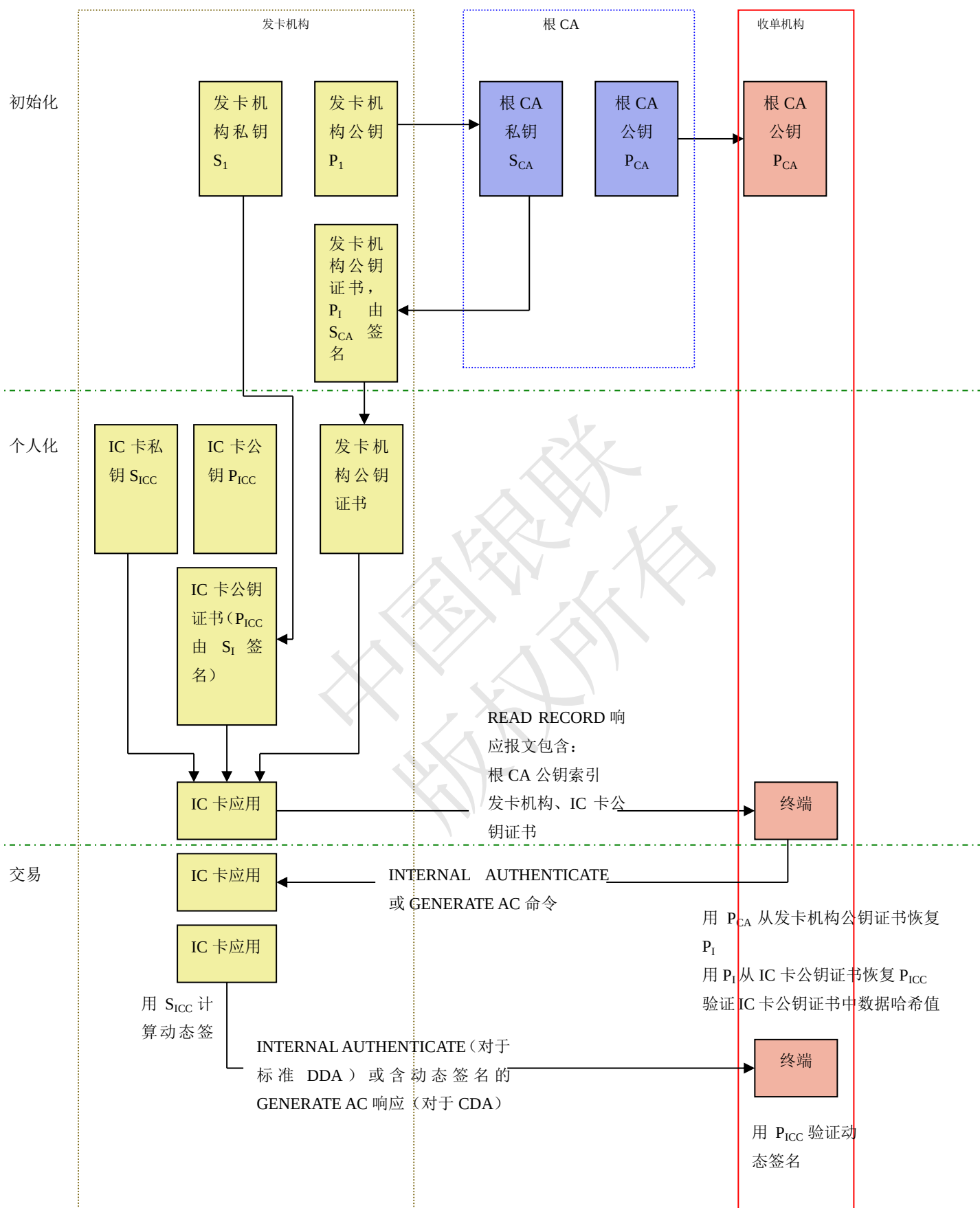


图2 银联标准 IC 卡动态数据认证

银联标准IC卡标准动态数据认证整体过程说明如下：

- 1) 发卡机构密钥管理系统产生发卡机构公私钥对 S_i 和 P_i ，并将发卡机构公钥 P_i 传送至根 CA；
- 2) 根 CA 用自己的私钥 S_{CA} 对发卡机构公钥进行数字签名，产生发卡机构公钥证书，连同根 CA 公钥证书（包括 RID 和根 CA 公钥索引）返回给发卡机构密钥管理系统；
- 3) 发卡机构密钥管理系统为每一张银联标准 IC 卡产生一对公私钥对 S_{ICC} 和 P_{ICC} ，并用发卡机构私钥 S_i 对 IC 卡公钥 P_{ICC} 进行数字签名，产生 IC 卡公钥证书；
- 4) 发卡机构密钥管理系统将发卡机构公钥证书、IC 卡公钥证书、IC 卡私钥、RID 以及根 CA 公钥索引传送至发卡系统；
- 5) 发卡系统在个人化时将发卡机构公钥证书、IC 卡公钥证书、IC 卡私钥、RID 及根 CA 公钥索引写入卡片中；
- 6) 根 CA 将其公钥 P_{CA} 、RID、根 CA 公钥索引及其它相关信息经收单机构传送至终端管理系统；
- 7) 收单机构终端管理系统把根 CA 公钥 P_{CA} 、RID、根 CA 公钥索引及其它相关信息下载至终端；
- 8) 银联标准 IC 卡进行交易时的脱机标准动态数据认证过程如下：
 - 终端从卡片读取发卡机构公钥证书、IC 卡公钥证书、RID 以及根 CA 公钥索引，利用 RID 和根 CA 公钥索引定位根 CA 公钥 P_{CA} ，使用根 CA 公钥 P_{CA} 恢复出发卡机构公钥 P_i 并验证其有效性，使用恢复的发卡机构公钥 P_i 恢复出 IC 卡公钥 P_{ICC} 并验证其有效性；
 - 终端向 IC 卡发送内部认证命令（INTERNAL AUTHENTICATE）（见《中国金融集成电路（IC）卡规范》）请求一个动态签名；卡片对内部认证命令中的终端数据和 IC 卡交易动态数据进行连接，由 IC 卡私钥 S_{ICC} 对该连接数据进行数字签名并返回给终端；
 - 终端使用 IC 卡公钥 P_{ICC} 对上一步骤的数字签名进行验证。

5.1.3 复合动态数据认证/应用密文生成（CDA）

该方式在第一个请求应用密文命令发出后执行（见《中国金融集成电路（IC）卡规范》）。银联标准IC卡来自卡片的数据包括应用密文以及来自终端的数据生成一个数字签名。

银联标准IC卡复合动态数据认证/应用密文生成的整体过程如下：

- 1) 发卡机构密钥管理系统产生发卡机构公私钥对 S_i 和 P_i ，并将发卡机构公钥 P_i 传送至根 CA；
- 2) 根 CA 用自己的私钥 S_{CA} 对发卡机构公钥进行数字签名，产生发卡机构公钥证书，连同根 CA 公钥证书（包括 RID 和根 CA 公钥索引）返回给发卡机构密钥管理系统；
- 3) 发卡机构密钥管理系统为每一张银联标准 IC 卡产生一对公私钥对 S_{ICC} 和 P_{ICC} ，并用发卡机构私钥 S_i 对 IC 卡公钥 P_{ICC} 进行数字签名，产生 IC 卡公钥证书；
- 4) 发卡机构密钥管理系统将发卡机构公钥证书、IC 卡公钥证书、IC 卡私钥、RID 以及根 CA 公钥索引传送至发卡系统；
- 5) 发卡系统在个人化时将发卡机构公钥证书、IC 卡公钥证书、IC 卡私钥、RID 及根 CA 公钥索引写入卡片中；
- 6) 根 CA 将其公钥 P_{CA} 、RID、根 CA 公钥索引及其它相关信息经收单机构传送至终端管理系统；
- 7) 收单机构终端管理系统把根 CA 公钥 P_{CA} 、RID、根 CA 公钥索引及其它相关信息下载至终端；
- 8) 银联标准 IC 卡进行交易时的脱机复合动态数据认证过程如下：
 - 终端从 IC 卡中读取发卡机构公钥证书、IC 卡公钥证书、RID 及根 CA 公钥索引。
 - 终端使用 RID 和根 CA 公钥索引定位根 CA 公钥 P_{CA} ，使用根 CA 公钥 P_{CA} 验证发卡机构公钥证书的签名并恢复出发卡机构公钥 P_i 。
 - 终端使用发卡机构公钥 P_i 验证 IC 卡公钥证书的签名并恢复出 IC 卡公钥 P_{ICC} 。
 - 终端生成一不可预知数并与其它相关数据一并传给 IC 卡。
 - IC 卡使用其自身的私钥 S_{ICC} 对收到的终端数据（包括不可预知数、交易数据）和其它 IC 卡数据（包括 TC/ARQC）做数字签名并发送给终端。
 - 终端使用 IC 卡公钥 P_{ICC} 验证 IC 卡传递的签名数据。

5.2 金融 IC 卡借记/贷记应用使用的公钥种类

在金融IC卡借记/贷记应用公钥认证体系中使用三种公私钥对：根CA公私钥对、发卡机构公私钥对和银联标准IC卡公私钥对。其作用如表1所示。

表1 金融 IC 卡借记/贷记应用公钥认证体系使用的公钥种类

密钥名称	存在条件	用途
根 CA 公私钥对	必须存在	用于对发卡机构签发公钥证书
发卡机构公私钥对	支持 SDA 或 DDA	用于对静态数据进行数字签名，以及对 IC 卡签发公钥证书 用于动态数据认证
IC 卡公私钥对	支持 DDA	用于动态数据认证

6 根 CA 公钥文件

根CA公钥证书以根CA公钥文件形式进行传递。

6.1 根 CA 公钥文件命名

根CA公钥文件名格式为：01010000.CAA。其中：

- 01010000 标识银联借记/贷记服务；
- C 标识中国银联；
- AA 为根 CA 的公钥索引，以 0xAA 表示。

例如：01010000.C01。

6.2 根 CA 公钥文件内容

根CA公钥文件是二进制数据，其格式和内容如表2所示。

表2 根 CA 公钥文件内容

字段名	长度（字节数）	描述
未签名根 CA 公钥输出扩展	$35 + N_{CA} + e_{CA}$ 这里 N_{CA} 和 e_{CA} 分别是根 CA 公钥模长度和公钥指数长度，以字节数表示	见本标准第 6.3 节
自签名根 CA 公钥	N_{CA}	见本标准第 6.4 节

6.3 未签名根 CA 公钥输出扩展

未签名根CA公钥输出扩展是根CA公钥文件的第一部分，其内容如表3所示。

表3 未签名根 CA 公钥输出扩展

字段名	长度（字节数）	描述	格式
记录头	1	十六进制 ‘20’	b
服务标识	4	标识一个中国银联借记贷记服务，将相应应用的私有应用标识扩展(PIX)，右补十六进制 ‘0’ 构成。 ‘01010000’ = 借、贷记 ‘01010100’ = 借记 ‘01010200’ = 贷记 ‘01010300’ = 准贷记	b

字段名	长度（字节数）	描述	格式
		‘01010600’ = 储值型电子现金	
根 CA 公钥模长	2	根 CA 公钥模的长度 N_{CA} ，以十六进制表示。 N_{CA} 是一个偶数	b
根 CA 公钥算法标识	1	表示生成根 CA 公钥的密码算法	b
根 CA 公钥指数长度	1	根 CA 公钥指数长度 e_{CA} ，以十六进制表示	b
注册的应用提供商标识 (RID)	5	标识银联 RID，为十六进制 ‘A000000333’	b
根 CA 公钥索引	1	唯一标识根 CA 公钥	b
根 CA 公钥模	N_{CA}	根 CA 公钥模	b
根 CA 公钥指数	e_{CA}	根 CA 公钥指数	b
哈希值	20	本表第 6 到第 9 项的（从 RID 到根 CA 公钥指数）连接数据的哈希值	b

注：储值型电子现金，或称为纯电子现金，即后台无对应的借记/贷记账户

6.4 自签名根 CA 公钥

自签名根CA公钥是根CA公钥文件的第二部分。自签名根CA公钥是根CA按照《中国金融集成电路(IC)卡规范》第七部分第12章规定的签名算法利用根CA签名私钥对根CA公钥证书数据(表4进行签名所得)。

表4 根 CA 公钥证书数据

字段名	长度（字节数）	描述	格式
记录头	1	十六进制 ‘21’	b
服务标识	4	标识一个中国银联借记贷记服务，将相应应用的私有应用标识扩展(PIX)，右补十六进制 ‘0’ 构成。 ‘01010000’ = 借、贷记 ‘01010100’ = 借记 ‘01010200’ = 贷记 ‘01010300’ = 准贷记 ‘01010600’ = 储值型电子现金	b
注册的应用提供商标识 (RID)	5	标识银联 RID：为十六进 ‘A000000333’	b
根 CA 公钥索引	1	唯一标识根 CA 公钥	b
证书失效日期	2	月和年(MMY)，在该月最后一日之后证书失效	n 4
根 CA 公钥算法标识	1	十六进制 ‘01’ 标识生成根 CA 公钥的公钥算法，见《中国金融集成电路 (IC) 卡规范》第七部分第 12 章。	b
根 CA 公钥模的左边部分	$N_{CA} - 36 + e_{CA}$	根 CA 公钥模的左边 $N_{CA} - 36 + e_{CA}$ 字节，这里 N_{CA} 和	b

字段名	长度（字节数）	描述	格式
		e_{CA} 分别表示根 CA 公钥模长和公钥指数长度。	
哈希算法标识	1	十六进制 ‘01’，标识生成哈希值的哈希算法，见《中国金融集成电路（IC）卡规范》第七部分第 12 章。	b
根 CA 公钥指数长度	1	为十六进制字节数，表示根 CA 公钥指数长度 e_{CA} 。	b
根 CA 公钥指数	e_{CA}	根 CA 公钥指数。	b
哈希值	20	下列数据连接后计算的哈希值：RID、根 CA 公钥索引、根 CA 公钥模、根 CA 公钥指数。	b

表4根CA公钥证书数据中哈希值的计算见《中国金融集成电路（IC）卡规范》第七部分第12章。

7 成员机构根 CA 公钥证书验证

成员机构收到根CA公钥文件后，必须按照下列步骤对根CA公钥证书（根CA公钥文件）进行验证，验证成功后方可使用根CA测试及生产型公钥。成员机构使用从自签名根CA公钥数据解析出的哈希值来验证根CA公钥。

- 1) 按照未签名根 CA 公钥输出扩展中根 CA 公钥算法标识规定的公钥算法，使用未签名根 CA 公钥输出扩展中的根 CA 公钥模和根 CA 公钥指数，将自签名根 CA 公钥恢复出根 CA 公钥证书数据（见表 4）。
- 2) 检查恢复的根 CA 公钥证书数据中的记录头，若不是 ‘21’，则拒绝该根 CA 公钥证书。
- 3) 从恢复的根 CA 公钥证书数据中的注册应用提供者标识（RID），若不是 A000000333，则拒绝该根 CA 公钥。
- 4) 检查恢复的根 CA 公钥证书数据中的根 CA 公钥索引，若不符合本标准和《金融 IC 卡借记/贷记应用根 CA 公钥认证管理规则》，则拒绝该根 CA 公钥。
- 5) 检查恢复的根 CA 公钥证书数据中根 CA 公钥失效日期，若失效日期早于当前日期，则拒绝该根 CA 公钥。
- 6) 检查恢复的根 CA 公钥证书数据中根 CA 公钥算法标识，若不是 ‘01’，则拒绝该根 CA 公钥。
- 7) 检查恢复的根 CA 公钥证书数据中根 CA 公钥模长度，若该公钥模长度不符合《金融 IC 卡借记/贷记应用根 CA 公钥认证管理规则》第 6.2.2.1 节的规定，则拒绝该根 CA 公钥。
- 8) 检查根 CA 自签名数据和恢复的根 CA 公钥证书数据长度是否一致，并且数据长度都是 N_{CA} 字节，若不是，则拒绝该根 CA 公钥。
- 9) 检查恢复的根 CA 公钥证书数据中根 CA 公钥指数长度，若不是 ‘01’，则拒绝该根 CA 公钥。
- 10) 检查恢复的根 CA 公钥证书数据中根 CA 公钥指数，若不是 3 或 $2^{16}+1$ ，则拒绝该根 CA 公钥。
- 11) 从记录头到根 CA 公钥指数将恢复的根 CA 公钥数据的各字段从左向右连接。
- 12) 按照根 CA 公钥数据中的哈希算法标识确定的哈希算法对上一步骤得到的数据计算哈希值。
- 13) 比较上一步骤计算的哈希值和恢复的根 CA 公钥数据中的哈希值，若不同，则拒绝该根 CA 公钥。
- 14) 将恢复的根 CA 公钥证书数据中的根 CA 公钥指数与未签名根 CA 公钥输出扩展中的根 CA 公钥指数比较，若不同，则拒绝该根 CA 公钥。
- 15) 将恢复的根 CA 公钥证书数据中根 CA 公钥模的左边部分（ $N_{CA} - 36 + e_{CA}$ 字节）与未签名根 CA 公钥输出扩展中的根 CA 公钥模的前 $N_{CA} - 36 + e_{CA}$ 字节比较，若不同，则拒绝该根 CA 公钥。

若上述验证都通过，则成员机构可以接受所收到的根CA公钥。成员机构可以使用根CA公钥认证处理软件完成上述验证。

8 发卡机构公钥输入文件

8.1 基本要求

发卡机构为获得发卡机构生产型公钥证书或测试型公钥证书，需向中国银联提交发卡机构公钥证书申请，包括发卡机构公钥输入文件（电子版）和发卡机构公钥证书申请表（电子版）。发卡机构公钥输入文件的具体格式和要求见本标准第8.2、8.3、8.4节之规定。发卡机构公钥证书申请流程见Q/CUP 046.6.1规范的第7.1节。

8.2 发卡机构公钥输入文件命名

公钥输入文件的文件名格式为：“YLTTTTTT.INP”。其中“YL”为前缀；“TTTTTT”是记录号，唯一标识一个发卡机构的一次公钥证书申请，由银联统一管理和分发，发卡机构必须使用该记录号。例如：YL123456.INP。

8.3 发卡机构公钥输入文件结构

发卡机构公钥输入文件是一个二进制文件，由两部分组成，如表5所示。

表5 公钥输入文件

字段名	长度（字节数）	描述
未签名发卡行公钥输入扩展	$7 + N_i + e_i$	见本标准第8.4.1节。这里 N_i 是发卡机构公钥模长的字节数， e 为发卡机构公钥指数长度的字节数。
自签名发卡行公钥数据	N_i	见本标准第8.4.2节。

8.4 发卡机构公钥输入文件格式

8.4.1 未签名发卡机构公钥输入扩展

未签名发卡机构公钥输入扩展是发卡机构公钥输入文件的第一部分。该输入扩展提供发卡机构公钥信息，具体格式见表6。

表6 未签名发卡机构公钥输入扩展

字段名	长度（字节数）	描述	编码格式
记录头	1	十六进制值 ‘22’	b
发卡机构公钥模长	1	发卡机构公钥模长(N_i)的十六进制值(字节数)	b
发卡机构公钥模	Var	未经签名的发卡机构公钥模(N_i)	b
发卡机构公钥指数长度	1	发卡机构公钥指数长度 (e) (字节数)	b
发卡机构公钥指数	Var	发卡机构公钥指数	b
发卡机构公钥算法标识	1	标识用于发卡机构公钥的数字签名算法，见《中国金融集成电路（IC）卡规范》第七部分第12章	b
记录号	3	发卡机构公钥证书申请记录号	n 6

8.4.2 自签名发卡机构公钥数据

自签名发卡机构公钥数据是发卡机构公钥输入文件的第二部分，发卡机构利用所申请发卡机构公钥证书中的公钥对应的私钥对该发卡机构公钥数据进行签名。根CA使用该发卡机构公钥来验证签名的公钥数据。

发卡机构使用发卡机构私钥对发卡机构公钥数据（表4中的所有数据）进行签名，形成自签名发卡机构公钥数据。其中，发卡机构私钥应与提交给中国银联的发卡机构公钥相对应，签名算法参见《中国金融集成电路（IC）卡规范》第七部分第12章的数字签名算法。自签名发卡机构公钥数据的长度必须等于用来签名的发卡机构公私钥对中公钥的长度。

表4中的哈希值是将表4中除了哈希值外所有数据依原有顺序连接后进行哈希计算得到的。该哈希值仅用于根CA对发卡机构提交的公钥数据进行认证，与组成发卡机构公钥证书的哈希值不是同一个值。

表7 发卡机构公钥数据

字段名	长度（字节）	描述	格式
记录头	1	十六进制 ‘23’	b
服务标识	4	标识一个中国银联借记贷记服务，将相应应用的私有应用标识扩展(PIX)，右补十六进制 ‘0’ 构成。 ‘01010000’ = 借、贷记 ‘01010100’ = 借记 ‘01010200’ = 贷记 ‘01010300’ = 准贷记 ‘01010600’ = 储值型电子现金	b
证书格式	1	十六进制 ‘02’	b
发卡机构标识	4	主帐号（PAN）最左面的 3-8 个数字。（不足部分右补十六进制数 ‘F’）	cn 8
证书失效日期	2	月和年(MMY)，在该月最后一天之后证书失效	n 4
记录号	3	发卡机构公钥证书申请记录号	n 6
哈希算法标识	1	标识用来产生哈希值的哈希算法，见《中国金融集成电路（IC）卡规范》第七部分第 12 章	b
发卡机构公钥算法标识	1	标识发卡机构使用的数字签名算法，见《中国金融集成电路（IC）卡规范》第七部分第 12 章	b
发卡机构公钥模长	1	以十六进制表示的发卡机构公钥模长(N_1)（字节数）	b
发卡机构公钥指数长度	1	以十六进制表示的发卡机构公钥指数长度（字节数）	b
发卡机构公钥模的左边部分	$N_1 - (39 + e)$	公钥模(N_1)的最左 $N_1 - (39 + e)$ 部分，这里 N_1 表示发卡机构公钥模长的字节数，e 表示发卡机构公钥指数所占的字节数	b
发卡机构公钥指数	e	发卡机构公钥指数，为 3 或 65537，以十六进制存储为 ‘03’ 或 ‘01 00 01’	b
哈希值	20	发卡机构公钥及其相关信息的哈希结果，为本表中除哈希值外从记录头依顺序到发卡机构公钥指数的哈希值	b

成员发卡机构生成自签名发卡机构公钥数据的流程如图3所示。

成员发卡机构可以使用根CA公钥认证处理软件完成上述发卡机构公钥证书输出文件的生成。

记录头 服务标识 记录头 证书格式 发卡机构标识 证书失效日期 记录号 哈希算法标识 发卡机构公钥
算法标识 发卡机构公钥模长 发卡机构公钥指数长度 发卡机构公钥模的左边部分 发卡机构公钥指数

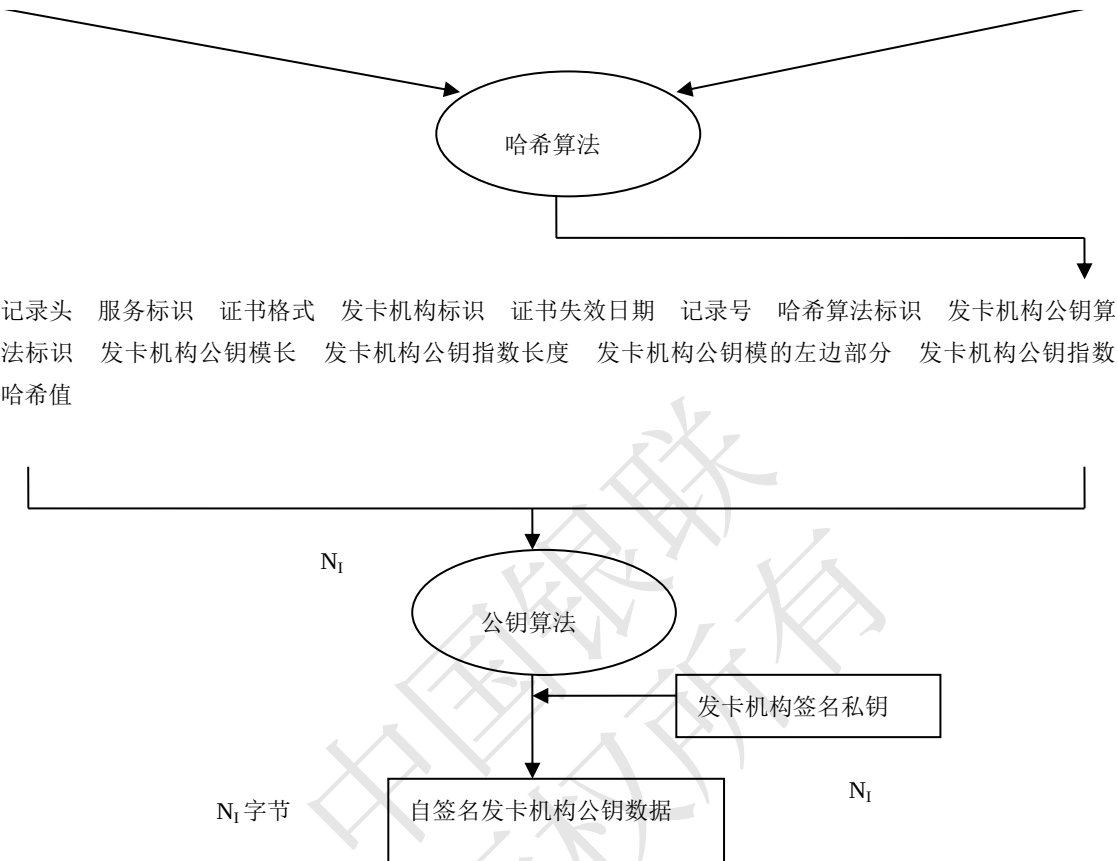


图3 生成自签名发卡机构公钥数据的流程

9 发卡机构公钥输入文件的验证

中国银联需对发卡机构公钥输入文件(包含未签名发卡机构公钥输入扩展和自签名发卡机构公钥数据)进行验证。中国银联按照下列步骤验证发卡机构公钥输入文件，并恢复发卡机构公钥数据。

- 1) 检查未签名发卡机构公钥输出扩展文件长度是否是 $7 + N_1 + e$ 字节，若不是，则中国银联拒绝该公钥证书申请。
- 2) 检查自签名发卡机构公钥数据是否为 N_1 个字节，若不是，则中国银联拒绝该公钥证书申请。
- 3) 检查未签名发卡机构公钥输入扩展中的公钥算法标识来验证其是否是十六进制‘01’。若不是，则该标识不符合《中国金融集成电路（IC）卡规范》，此时中国银联将拒绝该公钥证书申请。
- 4) 检查未签名发卡机构公钥输入扩展中的公钥长度是否为中国银联可接受的长度(小于或等于中国银联将用来签发该证书的公钥模长)，若不是，则中国银联拒绝该公钥证书申请。
- 5) 检查未签名发卡机构公钥输入扩展中的公钥指数长度是否为 1，若不是，则中国银联拒绝该公钥证书申请。
- 6) 检查未签名发卡机构公钥输入扩展中的公钥指数是否为 3，若不是，则中国银联拒绝该公钥证书申请。
- 7) 检查未签名发卡机构公钥输入扩展以获取发卡机构公钥模。
- 8) 使用《中国金融集成电路（IC）卡规范》第 7 部分第 12 章的数据恢复算法恢复发卡机构公

钥数据（表 4），以恢复发卡机构公钥数据。

9) 检查恢复的发卡机构公钥数据中记录头是否是十六进制 ‘23’，若不是，则中国银联拒绝该公钥证书申请。

10) 恢复的发卡机构公钥数据中证书格式是否是十六进制 ‘02’，若不是，则中国银联拒绝该公钥证书申请。

11) 恢复的发卡机构公钥数据中发卡机构标识。中国银联检查发卡机构标识是否是中国银联所接受的，若不是，则中国银联拒绝该公钥证书申请。

12) 恢复的发卡机构公钥数据中记录号和未签名发卡机构公钥输入扩展中的记录号是否相同，并且是否是中国银联安排的，若不是，则中国银联拒绝该公钥证书申请。

13) 检查恢复的发卡机构公钥数据中的发卡机构公钥指数长度是 1，若不是，则中国银联拒绝该公钥证书申请。

14) 检查恢复的发卡机构公钥数据中的发卡机构公钥指数是否是 3，若不是，则中国银联拒绝该公钥证书申请。

15) 检查恢复的发卡机构公钥数据中的发卡机构公钥算法标识和未签名发卡机构公钥输入扩展中的发卡机构公钥算法标识是否相同，若不是，则中国银联拒绝该公钥证书申请。

16) 检查恢复的发卡机构公钥数据中的发卡机构公钥模长和未签名发卡机构公钥输入扩展的发卡机构公钥模长是否相同，若不是，则中国银联拒绝该公钥证书申请。

17) 检查恢复的发卡机构公钥数据中的发卡机构公钥模左边 $N_1 - (39+e)$ 个字节和未签名发卡机构公钥输入扩展中的发卡机构公钥模左边 $N_1 - (39+e)$ 个字节是否相同，若不是，则中国银联拒绝该公钥证书申请。

18) 检查恢复的发卡机构公钥数据中的发卡机构哈希算法标识是否是十六进制 ‘01’，若不是，则中国银联拒绝该公钥证书申请。

19) 自左向右连接恢复的发卡机构公钥数据中从记录头到发卡机构公钥指数的各项数据。

20) 使用以哈希算法标识字段规定的哈希算法计算上一步骤得到的连接数据的哈希值。

21) 比较上一步骤计算的哈希值和恢复的发卡机构公钥数据(表 7)中的哈希值，若不同，则中国银联拒绝该公钥证书申请，若相同并且上述所有步骤的验证都成功，则中国银联接受该公钥证书的申请。

10 发卡机构公钥输出文件

在中国银联按照《金融IC卡借记/贷记应用根CA公钥认证管理规则》程序同意发卡机构公钥证书申请并将发卡机构公钥证书申请传递给根CA后，根CA签发该发卡机构公钥证书并产生一个发卡机构公钥证书输出文件。

发卡机构公钥证书输出文件由三部分组成，第一部分是未签名发卡机构公钥输出扩展，第二个部分是根CA对发卡机构公钥证书的签名，第三个部分是根CA公钥单独签名。各部分的组成详见本标准第10.3节、第10.4节和第10.5节。

10.1 发卡机构公钥证书输出文件命名

发卡机构公钥输出文件名格式为：AAAAAA.INN。其中：“AAAAAA”是申请记录号，与本标准第6.4节自签名发卡机构公钥数据中的记录号相同；I是固定值（‘I’）表示发卡机构；NN是用来签发发卡机构公钥证书的根CA公钥的索引。例如：010101.I01。

10.2 发卡机构公钥证书输出文件结构

发卡机构公钥证书输出文件的格式见表 8。

表8 发卡机构公钥证书输出文件

字段名	长度（字节数）	描述
未签名发卡机构公钥输出扩展	$17+e$ 若 $N_1 \leq N_{CA}+36$	见本标准第 710.3 节
	$53+N_1-N_{CA}+e$ 若 $N_1 > N_{CA}+36$	

	这里, e 、 N_I 、和 N_{CA} 分别表示发卡机构公钥指数字节数、发卡机构公钥模长字节数、和根 CA 用来生成该发卡机构公钥证书的公钥模长字节数	
签名的发卡机构公钥证书	N_{CA}	见本标准第 10.4 节
根 CA 单独签名	N_{CA}	见本标准第 10.5 节

10.3 未签名发卡机构公钥输出扩展

未签名发卡机构公钥输出扩展是发卡机构公钥输出文件的第一部分, 其格式见表9。该公钥输出扩展提供了该发卡机构公钥证书信息。

表9 未签名发卡机构公钥输出扩展

字段名	长度 (字节数)	描述	格式
记录头	1	十六进制值 '24'	b
服务标识	4	标识一个中国银联借记贷记服务, 将相应应用的私有应用标识扩展 (PIX), 右补十六进制 '0' 构成。 '01010000' = 借、贷记 '01010100' = 借记 '01010200' = 贷记 '01010300' = 准贷记 '01010600' = 储值型电子现金	b
发卡机构标识	4	主帐号 (PAN) 最左面的 3-8 个数字。(不足部分右补十六进制数 'F')	cn 8
证书序列号	3	由根 CA 系统分配的唯一标识证书的二进制数	b
证书失效日期	2	月和年(MMY), 在该月最后一天之后证书失效	n 4
发卡机构公钥 余项长度	1	发卡机构公钥模余项的长度	b
发卡机构公钥 余项	0 和 $(N_I - N_{CA} + 36)$ 的最大值	该字段仅在 $N_I > N_{CA} - 36$ 时存在, 由发卡机构公钥(N_I)的最低 $N_I - N_{CA} + 36$ 字节组成。	b
发卡机构公钥 指数长度	1	以十六进制表示的发卡机构公钥指数的长度 (字节数)	b
发卡机构公钥 指数	e	发卡机构公钥指数, 为 3 或 65537, 存储为十六进制 '03' 或 十六进制 '01 00 01'	b
根 CA 公钥索 引	1	根 CA 系统用来签发发卡机构公钥证书的公钥索引	b

10.4 签名的发卡机构公钥证书

签名的发卡机构公钥证书是发卡机构公钥证书输出文件的第二部分, 由根CA利用相应根CA私钥对表 10中的发卡机构公钥数据进行签名产生。

表10 发卡机构公钥证书数据

字段名	长度 (字节数)	描述	格式
恢复数据头	1	十六进制值 '6A'	b
证书格式	1	十六进制值 '02'	b
发卡机构标识	4	主帐号最左面的 3 到 8 位数字 (从第 1 位开始) (不足部分右补	cn 8

		十六进制 ‘F’)	
证书失效日期	2	月和年份(MMY) , 在本月最后一天之后证书失效	n 4
证书序列号	3	由根 CA 系统分配的唯一标识证书的十进制数	b
哈希算法标识	1	标识用来产生数字签名哈希值的哈希算法	b
发卡机构公钥算法标识	1	标识用于发卡机构公钥的数字签名算法	b
发卡机构公钥长度	1	以十六进制表示的发卡机构公钥的模长(N_1) (字节数)	b
发卡机构公钥指数长度	1	以十六进制表示的发卡机构公钥指数的长度 (字节数)	b
发卡机构公钥模的左边部分	$N_{CA} - 36$	如果 $N_1 \leq N_{CA} - 36$, 该字段包含了完整的发卡机构公钥模(N_1), 并在右面填充 $N_{CA} - 36 - N_1$ 个字节的 ‘BB’。 如果 $N_1 > N_{CA} - 36$, 该字段包含了发卡机构公钥模(N_1) 的最高 $N_{CA} - 36$ 字节	b
哈希值	20	发卡机构公钥及其相关信息的哈希结果	n
恢复数据尾	1	十六进制值 ‘BC’	b

根CA通过未签名发卡机构公钥输出扩展(表9)中的根CA公钥索引来定位根CA公钥及私钥, 并通过该根CA私钥对发卡机构公钥证书数据(表10)进行签名得到签名的发卡机构公钥证书。

10.5 根 CA 单独签名

由于未签名发卡机构公钥输出扩展没有经过根CA签名, 为保证其文件的数据完整性、信息源可认证性以及与签名的发卡机构公钥证书的有效绑定, 在发卡机构公钥证书输出文件中加入了根CA单独签名。根CA单独签名是发卡机构公钥证书输出文件的第三部分, 由根CA通过根CA私钥对根CA单独签名数据(表11)进行签名, 其中, 根CA私钥通过未签名发卡机构公钥输出扩展(表9)中的根CA公钥索引来定位, 使用的签名算法见《中国金融集成电路(IC)卡规范》第七部分第12章。

发卡机构对根CA单独签名的验证本标准不做强制性要求。

表11 根 CA 单独签名数据

文件	长度 (字节数)	描述	格式
记录头	1	十六进制 ‘00’	b
分组格式编码	1	十六进制 ‘01’	b
右边添加字符	$N_{CA}-24$	$N_{CA}-24$ 字节十六进制 ‘FF’	b
分隔符	1	十六进制 ‘00’	b
算法标识	1	根 CA 使用的哈希算法标识, 为十六进制 ‘01’	b
哈希值	20	对未签名发卡机构公钥输出扩展(表6)和发卡机构公钥证书数据(表7)进行连接后的数据计算哈希值	b

11 发卡机构公钥证书验证

发卡机构在收到中国银联为其颁发的发卡机构公钥证书后必须经过验证才可使用。发卡机构公钥证书是以发卡机构公钥证书输出文件(见本标准第10章)传递的, 发卡机构按照下列步骤验证发卡机构公钥证书:

- 1) 从发卡机构公钥证书输出文件的第一个数据(未签名发卡机构公钥输出扩展)中解析出根 CA 公钥索引, 判断发卡机构由《金融 IC 卡借记/贷记应用根 CA 公钥认证管理规则》第 6.2 节程序得到的根 CA 公钥证书中的公钥索引是否与该索引相同, 若不同则验证失败。

- 2) 发卡机构将发卡机构公钥证书输出文件的第二个数据（签名的发卡机构公钥证书）的长度与根 CA 公钥证书中的公钥模长比较，若不同则验证失败。
 - 3) 使用根 CA 公钥，按照《中国金融集成电路（IC）卡规范》第七部分第 12 章规定的公钥算法对发卡机构公钥证书输出文件的第二个数据（签名的发卡机构公钥证书）作数据恢复运算，恢复发卡机构公钥证书数据（见表 10），若恢复数据结尾不是‘BC’，则验证失败。
 - 4) 检查恢复的发卡机构公钥证书数据的数据头，若不是‘6A’，则验证失败。
 - 5) 检查恢复的发卡机构公钥证书数据的证书格式，若不是‘02’，则验证失败。
 - 6) 从“证书格式”到“发卡机构公钥左边部分”将恢复的发卡机构公钥证书数据的各字段进行连接。
 - 7) 对上一步骤的连接数据按照《中国金融集成电路（IC）卡规范》第七部分第 12 章规定的哈希算法计算哈希值。
 - 8) 比较上一步骤计算的哈希值和恢复的发卡机构公钥证书数据中的哈希值，若不同，则验证失败。
 - 9) 检查发卡机构标识，若不是银联所接受的，则验证失败。
 - 10) 检查证书失效日期，如不正确，则验证失败。
 - 11) 检查发卡机构哈希算法标识，若不是‘01’，则验证失败。
 - 12) 检查发卡机构公钥算法标识，若不是‘01’，则验证失败。
 - 13) 如果上述所有验证都是正确的，则发卡机构公钥证书验证成功。将发卡机构公钥模的左边部分与发卡机构公钥模余项连接，得到完整的发卡机构公钥模。
- 成员机构可以使用根 CA 公钥认证处理软件完成上述验证。

参考文献

EMV2000 Integrated Circuit Card Specification for Payment Systems: Book1~Book4

中国银联
版权所有